

Data Classification & Handling Policy

1. Purpose

This policy establishes a data classification framework for Summit IT Services and defines handling requirements for each classification level. Properly classifying and handling data reduces the risk of unauthorized disclosure, regulatory non-compliance, and reputational harm. All employees who create, receive, process, or store Summit IT Services data are responsible for applying these standards.

2. Scope

This policy applies to:

- All Summit IT Services data in any format: digital files, email, printed documents, verbal communications, and data at rest or in transit.
- All employees, contractors, and third parties who handle Summit IT Services data.
- All systems used to create, store, process, or transmit Summit IT Services data, including Microsoft 365 (OneDrive, SharePoint, Exchange), Slack, Zoom, local device storage, and external media.

3. Policy Statements

3.1 Data Classification Levels

Summit IT Services uses four data classification levels:

Level	Label	Description	Examples
1	Public	Approved for unrestricted distribution outside Summit IT Services	Marketing materials, published blog posts, job postings, public pricing
2	Internal	Not intended for external distribution; low harm if disclosed	Internal announcements, general IT procedures, meeting agendas, org charts

3	Confidential	Sensitive business information; significant harm if disclosed	Client contracts, financial reports, strategic plans, employee salary data, vendor agreements
4	Restricted	Highly sensitive; disclosure could cause severe harm or legal liability	Personal health information (PHI), personal financial data, credentials, encryption keys, regulated personal data, M&A data

3.1.1 Data without an explicit classification label is treated as **Internal** by default until properly reviewed and labeled.

3.1.2 Employees who create documents must apply the appropriate classification label. In Microsoft 365, this is achieved using **Microsoft Purview sensitivity labels** (visible in Office apps under the Sensitivity toolbar button):

Label in Purview	Classification
Public	Public
Internal	Internal
Confidential	Confidential
Highly Confidential	Restricted

3.1.3 SharePoint libraries and Teams channels that hold Confidential or Restricted data must have the appropriate Purview container label applied by the site owner. IT Security conducts quarterly audits of label coverage.

3.2 Handling Requirements by Classification Level

3.2.1 Public Data

- May be shared freely via any channel, including external email, social media, and public websites.
- No special storage, access control, or disposal requirements beyond normal records retention.

3.2.2 Internal Data

- May be shared with all Summit IT Services employees and authorized contractors.
- Must not be shared externally without manager approval.

- Store in SharePoint, OneDrive for Business, or other IT-approved repositories. Do not store on personal cloud storage.
- Dispose of printed copies in standard recycling if they contain no Confidential or Restricted elements.

3.2.3 Confidential Data

Handling Aspect	Requirement
Access	Need-to-know basis; controlled via SharePoint/OneDrive permissions and Okta group membership
Storage	SharePoint/OneDrive with "Confidential" sensitivity label; encrypted at rest
Email	Encrypt outbound email via Microsoft Purview; mark subject with [CONFIDENTIAL]
External sharing	Requires manager and Legal approval; use Microsoft Purview protected sharing
Printing	Print using PaperCut Secure Print (release at MFP with badge/PIN); retrieve immediately
Physical documents	Store in locked cabinets when not in use
Disposal	Shred using cross-cut shredder or locked shred bins; do not place in general recycling
Transmission	Must be encrypted in transit (TLS 1.2+); do not send via unsecured channels
Removable media	Prohibited for Confidential data unless encrypted USB approved by IT; log usage in ticket

3.2.4 Restricted Data

Handling Aspect	Requirement
Access	Strictly limited; access requires explicit approval from data owner and IT Security
Storage	Designated Restricted SharePoint sites or approved secure repositories only; "Highly Confidential" label required

Email	Encrypted end-to-end; avoid emailing Restricted data where possible; use secure file share instead
External sharing	Requires VP-level approval, Legal review, and executed NDA/DPA with recipient; use Purview protected link only
Printing	Prohibited unless explicitly approved by data owner; if approved, use Secure Print and immediately place in locked document bag
Physical documents	Two-person rule for transport; locked in fire-rated safe when not in active use
Disposal	On-site cross-cut shredding per NIST 800-88 guidelines; documented destruction certificate required
Transmission	Encrypted in transit (TLS 1.3 preferred); consider Purview Information Protection or secure file transfer solution
Removable media	Prohibited
Screen visibility	Laptop screens must use privacy screens; avoid displaying in public spaces

3.3 Data Labeling

3.3.1 Employees must apply the correct Purview sensitivity label at the time of document creation. Labels are available in Word, Excel, PowerPoint, Outlook, and Teams.

3.3.2 Purview auto-labeling policies are configured to detect common Restricted data patterns (credit card numbers, Social Security Numbers, health information keywords) and apply the Highly Confidential label automatically. Employees must not override auto-applied labels to a lower classification without written approval from the data owner.

3.3.3 Physical documents containing Confidential or Restricted data must be stamped or header/footer labeled with the appropriate classification level on every page.

3.4 Data Storage Locations

Approved storage locations by classification:

Classification	Approved Locations	Prohibited Locations
----------------	--------------------	----------------------

Public	SharePoint, OneDrive, external websites	N/A
Internal	SharePoint, OneDrive, Teams, company laptop local drive	Personal cloud (Dropbox, iCloud personal, Google Drive personal)
Confidential	SharePoint (labeled), OneDrive (labeled), encrypted archive	Unencrypted email attachments, Slack (direct messages), USB without encryption
Restricted	Designated Restricted SharePoint sites, approved vault systems	Any non-IT-approved location; Slack; Teams general channels; email

3.5 Data Retention

Data must be retained and disposed of in accordance with POL-011 (Data Backup & Retention Policy). Employees must not delete data subject to a legal hold or regulatory retention requirement. Legal hold notifications are issued by the Legal team via email and the SummitDesk portal.

3.6 Data Breach Notification

Any suspected loss, theft, or unauthorized disclosure of Confidential or Restricted data must be reported to the Security Operations Center immediately at soc@summitit.com or via #it-help on Slack, 24/7. Incidents involving Restricted (especially regulated) data trigger the Incident Response process; IT Security will notify Legal and, if required, affected individuals or regulators within required timeframes.

4. Roles & Responsibilities

Role	Responsibility
All Employees	Classify data at creation; apply Purview labels; handle data per this policy; report suspected breaches
Data Owners (business unit leaders)	Define classification for data in their domain; approve access to Confidential/Restricted data; review classification quarterly
IT Security & Compliance	Own policy; configure Purview DLP and labeling; conduct audits; manage breach response
L3 Engineering	Configure SharePoint/OneDrive permissions, Purview policies, and DLP rules

Legal	Advise on regulatory requirements; issue legal holds; approve Restricted data external sharing
HR	Ensure employee classification training completion; support investigations

5. Enforcement & Consequences

Mishandling of data according to its classification level is a serious policy violation:

- **Labeling omissions or errors (unintentional):** Correction required; additional training.
- **Storing Confidential/Restricted data in unapproved locations:** Written warning; data moved to approved location; IT review of other storage.
- **Sharing Confidential/Restricted data without authorization:** HR investigation; suspension of data access; potential termination.
- **Data breach resulting from policy non-compliance:** HR/Legal investigation; possible termination; regulatory and legal consequences.

6. Exceptions

Exceptions (e.g., business need to store Restricted data in a non-standard system) must be approved by the data owner, IT Security & Compliance, and Legal. All exceptions must document compensating controls and have an expiration date not exceeding 90 days.

7. Related Documents

- POL-001 - Acceptable Use Policy
- POL-008 - Email & Communications Policy
- POL-009 - Access Control & Least Privilege Policy
- POL-011 - Data Backup & Retention Policy
- REF-0001 - Summit IT Environment Standards
- Microsoft Purview Labeling Guide (internal wiki)
- Data Breach Response Runbook (internal runbook)

8. Revision History

Version	Date	Author	Summary of Changes
1.0	2020-11-01	IT Security	Initial data classification framework (three levels)

2.0	2022-06-01	IT Security & Compliance	Added Restricted tier; introduced Microsoft Purview labeling
2.1	2023-04-15	IT Security & Compliance	Added auto-labeling policy details; updated removable media prohibition for Restricted data
3.0	2024-01-15	IT Security & Compliance	Full rewrite; comprehensive handling tables per tier; aligned to Purview container labels; added SharePoint site labeling audit requirement
3.0.1	2025-10-01	IT Security & Compliance	Annual review; updated prohibited storage list; no structural changes